

10

Security Incidents: Phishing, Malware and Lost Devices

Suspicious emails, malware alerts, compromised accounts, lost or stolen equipment

Default priority: P1 Critical / P2 High, depending on impact

Target response / resolution: Respond in 5 to 15 min; contain immediately

Handled by: Tier 1 triage, then Security team

Scope

Use this instruction when a user reports a suspicious email, a security warning, signs of compromise, or a lost or stolen device. Speed matters more than perfect documentation.

Related instructions: WI-01 Password Reset, WI-05 Email and Calendar, WI-11 Mobile Devices

Common symptoms

- User clicked a link or opened an attachment in a suspicious email
- Antivirus or endpoint alert on a device
- Unexpected password change, MFA prompts the user did not trigger, or odd sent mail
- Laptop, phone, or access badge lost or stolen

Information to collect

- What happened, when, and what the user did (clicked, entered a password, downloaded a file)
- Sender, subject, and the link or file (get the original message, not a screenshot)
- Device, hostname, and location
- Whether other users received the same message

Resolution steps

- 1 Stay calm and act fast.** Thank the user for reporting. Tell them not to delete the message or restart the device unless told to, as this may remove evidence.
- 2 Raise the incident.** Create a security incident ticket at P2 or higher and notify the Security team by the on-call process. Do not wait for the investigation to finish.
- 3 Contain the account.** If credentials may be exposed, reset the password, revoke active sessions and tokens, and review MFA methods and mailbox forwarding rules.
- 4 Contain the device.** For malware, isolate the device from the network through the endpoint security tool, or ask the user to disconnect from the network. Do not power off unless told to.
- 5 Handle lost or stolen devices.** Lock or remotely wipe the device through device management, disable the account sessions, and record the loss time and location. The user should also report theft to the police if applicable.
- 6 Check for spread.** Search for the same message across mailboxes and remove it. Block the sender, link, or file hash with the Security team.
- 7 Inform and record.** Tell the user what has been done and what to expect. Record a clear timeline of actions in the ticket.

Escalate when

- Always involve the Security team for confirmed compromise, data exposure, or ransomware
- Multiple users affected or evidence of spread: declare a major incident
- Possible personal data breach: notify the Data Protection Officer without delay

Resolution and closure

- Close only after the Security team confirms containment and recovery
- Record lessons learned and send a security reminder to affected users
- Add the case to the security awareness training examples

Quick troubleshooting reference

Symptom	Likely cause	What to do
User clicked a phishing link	Credentials or malware exposure	Reset the password, revoke sessions, check the device, and alert the Security team.
Antivirus alert on a device	Malware or false positive	Isolate the device, run a full scan, and send details to Security.
Unknown MFA prompts	Password compromised and attacker is trying to sign in	Reset the password, revoke sessions, and review sign-in logs.
Mail forwarding rule the user did not create	Mailbox compromise	Remove the rule, reset credentials, and raise a security incident.
Laptop lost or stolen	Physical loss	Lock or wipe the device, disable sessions, and record the circumstances.

Suggested wording for the user

Open	<i>"Thank you for reporting this straight away. It is the right thing to do. Please do not shut down or delete anything yet."</i>
During	<i>"I am locking your account as a precaution and the Security team is reviewing. I will keep you updated."</i>
Close	<i>"The threat has been dealt with and your account is safe to use again. Here is what to watch for in future."</i>

Good practice

Do

- Act quickly and escalate early
- Preserve evidence such as the original email
- Keep a timeline of every action
- Thank users for reporting

Do not

- Do not blame or lecture the user
- Do not delete evidence
- Do not wait for confirmation before containing
- Do not discuss the incident outside the response team

Worked example

A user enters their password on a fake login page after an email about a parcel delivery.

Ticket note field	Entry
Issue reported	User entered credentials on a suspicious page at 10:05.
Checks performed	Sign-in log shows a login from another country at 10:12.
Cause	Phishing, credentials captured.
Action taken	Password reset, sessions revoked, forwarding rules removed, message purged from other mailboxes.
Result	No further access. Security closed the incident. User received a reminder.

Frequently asked questions

Q. Should we ever ask the user to shut down a suspected infected laptop?

Prefer isolating from the network and following the Security team's direction. Powering off can lose evidence, but if there is active damage, stopping it comes first.

Q. What if the user is embarrassed and delayed reporting?

Thank them and focus on the fix. Fast reporting matters more than blame, and shaming makes people hide incidents.

Q. When is a data breach reportable?

That decision belongs to Security, Legal, and the Data Protection Officer. Your job is to record facts and timings and escalate straight away.

Analyst checklist

- | | |
|--|--|
| ☐ Stay calm and act fast | ☐ Check for spread |
| ☐ Raise the incident | ☐ Inform and record |
| ☐ Contain the account | ☐ Ticket note completed using the standard template |
| ☐ Contain the device | ☐ User confirmed the issue is resolved |
| ☐ Handle lost or stolen devices | |

Preventing repeat tickets

- Run regular phishing awareness training
- Provide a one-click report button
- Enforce MFA for all accounts
- Encrypt all laptops and enable remote wipe